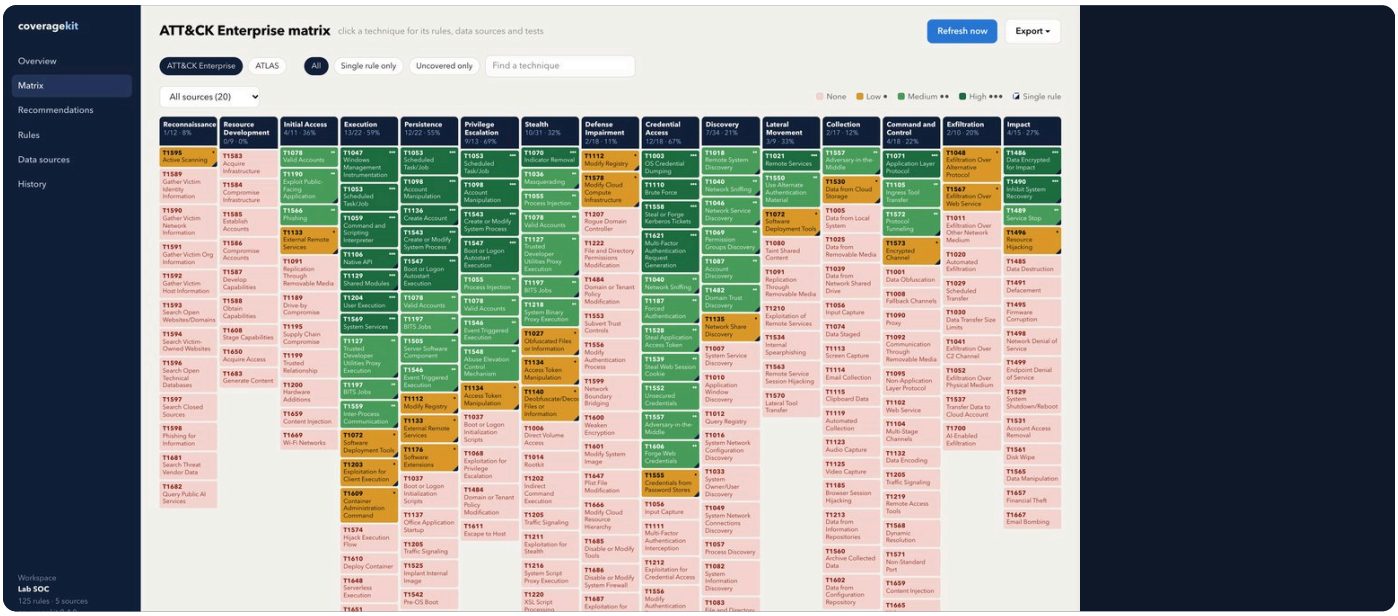
Leandro F. Juárez · Project

mitre-coverage-kit

I developed it myself as an open-source project, with the objective of letting a SOC measure its detection coverage instead of assuming it.



LINKS

github.com/lfjuarez/mitre-coverage-kit

The problem

Detection coverage is usually a belief ("we cover credential access") that nobody can measure. mitre-coverage-kit turns it into a measurement.

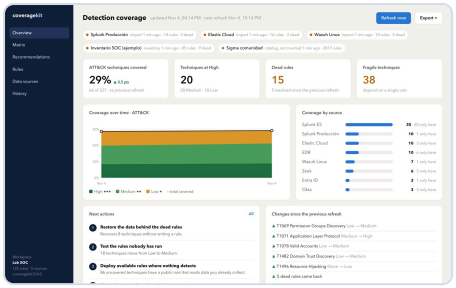
In detail

It is a Python tool (`coveragekit`) that reads the rules of one or several SIEMs, from exported files or straight from their APIs (Splunk Enterprise Security, Elastic Security, Wazuh, Microsoft Sentinel or Sigma), scores every MITRE ATT&CK Enterprise and MITRE ATLAS technique from 0 to 3 on a soft traffic light (uncovered, low, medium, high, with colour-blind-safe marks), exports an ATT&CK Navigator layer and a heat-map SVG, and produces reports in HTML, PDF, Excel, CSV, Markdown and JSON. It also lists dead rules: the ones that are enabled but can never fire because their data source is missing.

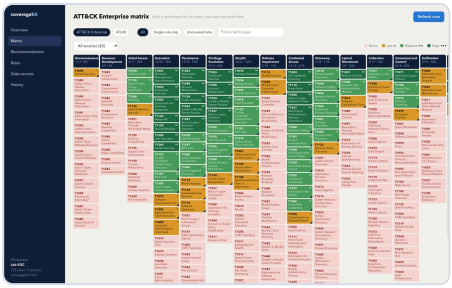
With `coveragekit serve` it runs a local web app that refreshes every source on a schedule and lets the SOC browse the result: key figures and their change, coverage over time and by source, the full ATT&CK and ATLAS matrices with filters, a panel per technique with its rules, the data each one is missing and its Atomic Red Team tests, recommendations, a history with a diff between refreshes, and export. Catalogs (for example the SigmaHQ repository) are rules that are available but not deployed: they never count as coverage, but for every technique nothing detects they list the public rules that would cover it, those that read data already collected first.

It bundles ATT&CK Enterprise v20 and ATLAS v5.6, ships a lab that runs the importers against real Splunk, Elastic and Wazuh instances in containers, and was tested against the full Wazuh default ruleset (4,499 rules) and the public SigmaHQ repository (3,162 rules). Something similar, at massive scale, I implemented at very large companies: coverage measurement and tracking across SIEMs from different vendors and in different environments (cloud, on-premise and hybrid), with an automated test battery and metadata-driven coverage tracking.

MIT licensed, with tests and continuous integration on every push.



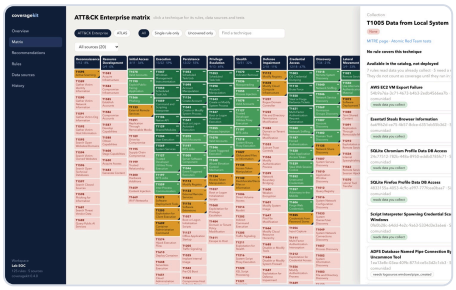
Overview: key figures and their change



ATT&CK matrix with the coverage levels



Technique panel: rules, missing data and tests



Catalog: public rules that would close each gap

Screenshots, documents and questions at leandrojuarez.info/projects?lang=en#mitre-coverage-kit-open-source